

Informe Ejecutivo — Auditoría de Seguridad de la Información

ISO 27001:2022 (Anexo A) · Ley 25.326 · Ley 26.529 | Gaspar Peralta — Auditor en formación ISO 27001 Lead Auditor PECB

Cliente	ejemplo	Ubicación	punta alta
Modalidad	Presencial	Fecha	no especificada (pendiente de completar)
Personal presente	ejemplo		

1. Resumen ejecutivo

33 Controles evaluados	0% Cumplidos formalmente	2.0 / 3 Madurez media	12 Riesgo alto	4 Zona crítica (matriz)
---------------------------	-----------------------------	--------------------------	-------------------	----------------------------

Nivel de riesgo general del consultorio: ALTO. De los 33 controles evaluados, ninguno fue marcado como formalmente cumplido en este relevamiento, aunque la madurez promedio (2,0 sobre 3) muestra que buena parte de las prácticas ya están definidas o gestionadas de hecho. El foco no es partir de cero, sino **formalizar y verificar** lo que ya funciona y **cerrar primero los 4 hallazgos** que combinan impacto alto con alta probabilidad de ocurrencia (ver matriz de riesgo, sección 5).

Distribución de hallazgos por nivel de riesgo: **12 altos**, **17 medios** y **4 bajos**, sobre un total de 33 controles del checklist ISO 27001 adaptado a consultorios médicos.

2. Activos identificados

Activo	Tipo	Criticidad
Historias clínicas digitales	Información	Crítica
Historias clínicas en papel	Físico	Crítica
Sistema de gestión de turnos	Software	Alta
PC / equipos del consultorio	Físico	Alta
Credenciales de acceso al sistema	Información	Alta
Router / red WiFi	Físico	Media
Disco externo / backup	Físico	Alta
Correo electrónico	Servicio	Media

3. Hallazgos por nivel de riesgo

Se listan primero los hallazgos de riesgo alto. Cada uno incluye el problema identificado, su impacto potencial, la recomendación concreta, la referencia normativa y la madurez actual relevada frente al objetivo recomendado.

Hallazgos de riesgo alto (12)

RIESGO ALTO · Datos de pacientes

1. ¿Los datos de pacientes están almacenados en sistemas con acceso restringido?

Problema: El sistema digital de historias clínicas cuenta con una regla de acceso definida, pero no se confirmó que se revise o audite periódicamente ni que cubra también el archivo en papel.

Impacto potencial: Sin verificación periódica, el control puede degradarse con el tiempo (contraseñas compartidas, accesos no revisados) sin que nadie lo note, exponiendo el activo más crítico del consultorio.

Recomendación: Formalizar por escrito la política de acceso (quién, cómo y con qué frecuencia se revisa) y extenderla explícitamente al archivo físico.

ISO: A.5.12 · Ley 25.326 Art.12 | Madurez actual: **Definido (2/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Datos de pacientes

2. ¿Solo el personal autorizado puede ver las historias clínicas?

Problema: Existe cierta restricción de acceso, pero no está basada en un criterio definido de "necesidad de conocer" según el rol de cada persona.

Impacto potencial: Personal administrativo podría estar accediendo a diagnósticos y datos sensibles que no necesita para su función, ampliando innecesariamente la exposición de datos de salud.

Recomendación: Definir por escrito qué información puede ver cada rol (médico vs. recepción) y configurar el sistema para reflejar esa distinción.

ISO: A.5.15 · Ley 26.529 Art.2 | Madurez actual: **Informal (1/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Accesos y usuarios

3. ¿El médico y la recepcionista tienen usuarios individuales en el sistema digital?

Problema: El sistema ya cuenta con usuarios individuales gestionados activamente para cada persona del consultorio.

Impacto potencial: Riesgo residual bajo; el impacto de no formalizarlo como "cumplido" es no tener evidencia documental ante una auditoría externa.

Recomendación: Documentar el proceso de alta de usuarios (quién lo autoriza y con qué información) para dejar constancia formal del control ya vigente.

ISO: A.5.16 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Accesos y usuarios

4. ¿Las contraseñas son únicas y no se comparten verbalmente ni por escrito?

Problema: Hay una regla clara de no compartir contraseñas, pero no se confirmó una verificación activa de su cumplimiento en el día a día.

Impacto potencial: Una práctica "definida pero no verificada" tiende a relajarse con el tiempo, sobre todo bajo presión de atención al paciente.

Recomendación: Reforzar la política con un recordatorio periódico al personal y forzar el cambio de contraseña ante cualquier sospecha de exposición.

ISO: A.5.17 | Madurez actual: **Definido (2/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Accesos y usuarios

5. Si se fuera la recepcionista hoy, ¿cambiarían sus accesos de forma inmediata?

Problema: No se pudo confirmar durante el relevamiento si existe un procedimiento de revocación inmediata de accesos ante la salida de personal.

Impacto potencial: Es uno de los vectores de fuga de datos más comunes en organizaciones chicas: un acceso no revocado queda disponible indefinidamente.

Recomendación: Confirmar en la próxima visita quién tiene la potestad de dar de baja accesos y documentar el procedimiento, aunque sea de una sola persona.

ISO: A.5.18 · Ley 25.326 Art.9 | Madurez actual: **No evaluada** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Copias de seguridad

6. ¿Realizan copias de seguridad del sistema digital de historias clínicas?

Problema: Existe una práctica definida de backup, pero no se confirmó evidencia de que se ejecute de forma consistente y con un responsable claro.

Impacto potencial: La Ley 26.529 exige conservar la historia clínica un mínimo de 10 años; un backup irregular pone en riesgo ese resguardo legal ante cualquier falla técnica.

Recomendación: Asignar formalmente un responsable del backup y dejar registro, aunque sea manual, de cada copia realizada.

ISO: A.8.13 · Ley 26.529 Art.15 | Madurez actual: **Definido (2/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Copias de seguridad

7. ¿Dónde se guardan los backups? ¿Están separados del equipo principal?

Problema: Los backups existen de forma informal, sin un criterio claro sobre su ubicación respecto del equipo principal.

Impacto potencial: Si el backup está en el mismo equipo o red que el original, no protege ante la falla más probable: rotura, robo o secuestro (ransomware) del equipo principal.

Recomendación: Migrar a un esquema de backup separado físicamente (disco externo desconectado o nube), siguiendo el principio 3-2-1.

ISO: A.8.13 | Madurez actual: **Informal (1/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Equipos y red

8. ¿Los equipos con datos de pacientes tienen antivirus activo y actualizado?

Problema: Hay un antivirus con política definida, pero no se confirmó que las definiciones estén al día en todos los equipos al momento de la visita.

Impacto potencial: Un antivirus con licencia vencida da una falsa sensación de seguridad mientras deja de proteger contra amenazas nuevas, incluyendo ransomware.

Recomendación: Verificar la fecha de última actualización en cada equipo y activar actualizaciones automáticas si no están.

ISO: A.8.7 | Madurez actual: **Definido (2/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Equipos y red

9. ¿El router tiene la contraseña por defecto cambiada?

Problema: La contraseña de administración del router ya fue cambiada y se gestiona correctamente.

Impacto potencial: Riesgo residual bajo; queda pendiente solo la formalización de este control como cumplido.

Recomendación: Registrar la fecha del último cambio de contraseña del router como buena práctica documental.

ISO: A.8.20 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Gestión de incidentes

10. ¿Saben qué harían si detectan que les robaron o perdieron datos de pacientes?

Problema: No existe un plan de reacción formal ante un incidente de seguridad; la respuesta dependería de la improvisación del momento.

Impacto potencial: La demora o el manejo incorrecto de un incidente amplifica el daño y puede derivar en responsabilidad legal por no gestionar adecuadamente la seguridad de los datos.

Recomendación: Redactar un procedimiento mínimo de una página: a quién avisar primero, qué hacer, y a quién notificar si hay datos comprometidos.

ISO: A.5.24 · Ley 25.326 Art.12 | Madurez actual: **Informal (1/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Cumplimiento legal

11. ¿Los pacientes firman un consentimiento informado para el tratamiento de sus datos?

Problema: El consultorio ya cuenta con un mecanismo gestionado de consentimiento informado para el tratamiento de datos.

Impacto potencial: Riesgo residual bajo; el pendiente es formalizar este punto como cumplido y confirmar que cubra también usos secundarios (ej. recordatorios por WhatsApp).

Recomendación: Revisar que el texto del consentimiento cubra explícitamente todos los usos actuales de los datos del paciente.

ISO: A.5.31 · Ley 25.326 Art.6 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Gestionado (3/3)**

RIESGO ALTO · Cumplimiento legal

12. ¿Están inscriptos como responsables de una base de datos ante la DNPDP?

Problema: La base de datos de pacientes ya se encuentra inscripta y gestionada ante el organismo de control.

Impacto potencial: Riesgo residual bajo; es uno de los requisitos legales más desconocidos en consultorios chicos, y aquí ya está resuelto.

Recomendación: Mantener actualizada la inscripción ante cualquier cambio relevante en el tratamiento de datos.

ISO: A.5.31 · Ley 25.326 Art.21 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Gestionado (3/3)**

Hallazgos de riesgo medio (17)

RIESGO MEDIO · Datos de pacientes

1. ¿Saben qué datos personales recopilan y dónde exactamente los guardan?

Problema: El consultorio ya tiene identificado y gestionado qué datos personales recopila y dónde los guarda.

Impacto potencial: Riesgo residual bajo; facilita cualquier respuesta futura ante un pedido de acceso o baja de datos por parte de un paciente.

Recomendación: Mantener el inventario actualizado cuando se incorporen nuevos sistemas o servicios.

ISO: A.5.9 · Ley 25.326 Art.8 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Datos de pacientes

2. ¿Las historias clínicas en papel están separadas del área de acceso general?

Problema: Las historias clínicas en papel ya están separadas del área de acceso general de forma gestionada.

Impacto potencial: Riesgo residual bajo.

Recomendación: Mantener la práctica actual y revisarla ante cualquier remodelación del espacio físico.

ISO: A.7.3 · Ley 26.529 Art.14 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Accesos y usuarios

3. ¿Las contraseñas tienen un mínimo de complejidad?

Problema: No hay un criterio mínimo de complejidad exigido para las contraseñas del sistema.

Impacto potencial: Contraseñas simples (nombre, fecha de nacimiento, "1234") son fáciles de adivinar por cualquiera con mínimo conocimiento del consultorio.

Recomendación: Configurar, si el sistema lo permite, un mínimo de longitud y combinación de caracteres.

ISO: A.5.17 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Accesos y usuarios

4. ¿El sistema de turnos tiene acceso diferenciado del sistema de historias clínicas?

Problema: El sistema de turnos y el de historias clínicas no tienen accesos diferenciados.

Impacto potencial: Personal que solo necesita gestionar la agenda termina con acceso a diagnósticos y datos médicos sin necesitarlo.

Recomendación: Evaluar con el proveedor del sistema si es posible separar permisos por función.

ISO: A.8.5 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Accesos y usuarios

5. ¿Las pantallas se bloquean automáticamente cuando no se usan por un tiempo?

Problema: Existe una configuración de bloqueo automático definida, pero no se confirmó el tiempo de espera configurado en cada equipo.

Impacto potencial: Un tiempo de bloqueo demasiado largo deja la sesión expuesta durante ausencias breves del personal.

Recomendación: Verificar y homogeneizar el tiempo de bloqueo en todos los equipos (recomendado: 2 a 5 minutos).

ISO: A.7.7 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Copias de seguridad

6. ¿Alguna vez probaron recuperar información de un backup?

Problema: Nunca se probó restaurar información desde una copia de backup.

Impacto potencial: Un backup no probado puede estar corrupto o incompleto sin que nadie lo sepa hasta el momento de una emergencia real.

Recomendación: Programar una prueba de restauración simple, de un solo archivo, al menos dos veces al año.

ISO: A.8.13 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Equipos y red

7. ¿El sistema operativo de los equipos está actualizado con los últimos parches?

Problema: El sistema operativo de los equipos ya se mantiene actualizado de forma gestionada.

Impacto potencial: Riesgo residual bajo.

Recomendación: Confirmar que las actualizaciones automáticas sigan activas tras cualquier reinstalación o cambio de equipo.

ISO: A.8.8 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Equipos y red

8. ¿La red WiFi del consultorio está separada de la que usan los pacientes?

Problema: Existe una separación definida entre la red del consultorio y la de pacientes, pero conviene confirmar que esté correctamente configurada.

Impacto potencial: Si la separación no es efectiva, un dispositivo de un paciente comprometido podría interactuar con la red donde están los equipos del consultorio.

Recomendación: Verificar con el proveedor de internet que la red de invitados esté aislada de la red principal.

ISO: A.8.20 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Equipos y red

9. ¿Usan software con licencia válida en los equipos del consultorio?

Problema: El software utilizado ya cuenta con licencias válidas y gestionadas.

Impacto potencial: Riesgo residual bajo.

Recomendación: Mantener un registro simple de licencias vigentes para futuras renovaciones.

ISO: A.8.19 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Seguridad física

10. ¿Las pantallas con datos de pacientes no son visibles desde la sala de espera?

Problema: Las pantallas ya están posicionadas de forma que no son visibles desde la sala de espera.

Impacto potencial: Riesgo residual bajo.

Recomendación: Revisar la disposición ante cualquier cambio de mobiliario.

ISO: A.7.7 · Ley 26.529 Art.2 | Madurez actual: **Gestionado (3/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Seguridad física

11. ¿El archivo de historias clínicas en papel está bajo llave o en área restringida?

Problema: Existe un criterio definido de resguardo del archivo en papel, pero conviene confirmar que el mecanismo de cierre se use de forma consistente.

Impacto potencial: Un archivero "con llave" pero sin usarla en la práctica equivale a no tenerla.

Recomendación: Confirmar que la llave se use y se guarde de forma responsable, sin dejarla puesta en la cerradura.

ISO: A.7.3 · Ley 26.529 Art.14 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Seguridad física

12. ¿El consultorio permanece cerrado con llave cuando no hay personal presente?

Problema: No hay una práctica consistente de cierre del consultorio durante ausencias breves del personal (almuerzo, entre turnos).

Impacto potencial: Con el consultorio vacío y sin llave, cualquier persona podría acceder físicamente a equipos encendidos y archivos.

Recomendación: Establecer una regla simple: cerrar con llave ante cualquier ausencia, aunque sea breve.

ISO: A.7.1 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Gestión de incidentes

13. ¿Tienen un contacto técnico de confianza para emergencias informáticas?

Problema: Existe un contacto técnico definido, pero conviene confirmar su disponibilidad real ante una emergencia.

Impacto potencial: Un contacto técnico no disponible en el momento crítico amplifica el tiempo de inactividad ante una falla o incidente.

Recomendación: Confirmar los tiempos de respuesta esperados y tener un contacto alternativo de respaldo.

ISO: A.5.24 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Gestión de incidentes

14. ¿El personal conoce conceptos básicos de seguridad? (phishing, contraseñas, links sospechosos)

Problema: Hay cierta noción básica de seguridad en el personal, pero no surge de una capacitación formal.

Impacto potencial: El phishing dirigido a profesionales de salud es una técnica de ataque documentada, dado el alto valor de los datos médicos en mercados ilegales.

Recomendación: Compartir una guía breve, de media carilla, con ejemplos de correos sospechosos y qué hacer ante ellos.

ISO: A.6.3 · Ley 25.326 Art.9 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Gestión de incidentes

15. ¿Saben qué hacer si ven un correo sospechoso o un programa raro en el equipo?

Problema: No hay un criterio claro de acción ante un correo o programa sospechoso.

Impacto potencial: Actuar por intuición (por ejemplo, hacer clic para "cerrar" un pop-up) puede propagar en vez de contener un incidente.

Recomendación: Establecer una regla simple: ante la duda, no abrir y consultar al contacto técnico antes de actuar.

ISO: A.6.3 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Cumplimiento legal

16. ¿El personal tiene algún compromiso formal de confidencialidad sobre los datos de pacientes?

Problema: Existe un criterio de confidencialidad entendido por el personal, pero no está formalizado por escrito.

Impacto potencial: Sin un documento firmado, es más difícil sostener una responsabilidad clara ante un incumplimiento.

Recomendación: Incorporar una cláusula simple de confidencialidad en el vínculo laboral existente.

ISO: A.6.6 · Ley 25.326 Art.10 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO MEDIO · Cumplimiento legal

17. ¿Los datos de pacientes se comparten con terceros (laboratorios, obras sociales, otros médicos)?

Problema: Hay un criterio definido para compartir datos con laboratorios y obras sociales, pero conviene confirmar el método de envío utilizado.

Impacto potencial: Compartir estudios o resultados por canales no seguros (email personal, WhatsApp sin control) expone datos sensibles en tránsito.

Recomendación: Confirmar y, de ser necesario, estandarizar un canal seguro para el envío de información a terceros.

ISO: A.5.31 · Ley 25.326 Art.11 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

Hallazgos de riesgo bajo (4)

RIESGO BAJO · Datos de pacientes

1. ¿Tienen algún criterio sobre cuánto tiempo conservan los datos de pacientes?

Problema: Existe un criterio definido sobre el tiempo de conservación de los datos, alineado con el mínimo legal.

Impacto potencial: Riesgo bajo; el principal punto de atención es no eliminar historias antes del plazo legal de 10 años.

Recomendación: Documentar por escrito el criterio de conservación aplicado.

ISO: A.5.12 · Ley 26.529 Art.15 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

RIESGO BAJO · Copias de seguridad

2. ¿Los documentos en papel tienen alguna copia o registro alternativo?

Problema: No se pudo confirmar si existe algún registro alternativo de las historias clínicas en papel.

Impacto potencial: Ante un incendio, inundación o extravío, podría perderse información sin ningún respaldo.

Recomendación: Evaluar en la próxima visita si conviene digitalizar gradualmente el archivo histórico en papel.

ISO: A.8.13 · Ley 26.529 Art.14 | Madurez actual: **No evaluada** → Objetivo: **Definido (2/3)**

RIESGO BAJO · Seguridad física

3. ¿Hay control sobre quién puede ingresar al área donde están los equipos y archivos?

Problema: No hay una separación clara entre el área de atención al paciente y la zona donde están los equipos.

Impacto potencial: Riesgo bajo, propio de la cercanía física esperable en un consultorio chico.

Recomendación: Considerar un mostrador o límite simple que marque la zona de acceso restringido.

ISO: A.7.2 | Madurez actual: **Informal (1/3)** → Objetivo: **Definido (2/3)**

4. ¿Tienen web o formularios online para turnos? ¿Tienen política de privacidad publicada?**Problema:** Existe un criterio definido respecto de la política de privacidad publicada online, si aplica.**Impacto potencial:** Riesgo bajo, principalmente de cumplimiento normativo antes que de exposición de datos.**Recomendación:** Confirmar que la política esté visible y accesible antes de que el paciente complete el formulario.ISO: A.5.31 · Ley 25.326 Art.6 | Madurez actual: **Definido (2/3)** → Objetivo: **Definido (2/3)**

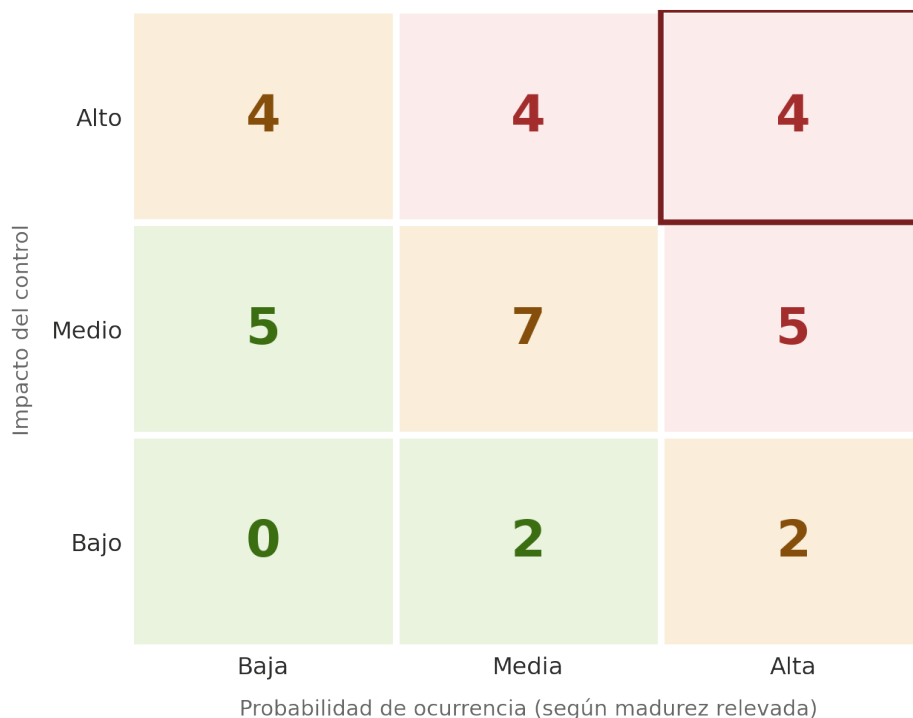
4. Puntos positivos

Ningún control quedó marcado como formalmente "cumplido" en este relevamiento, pero 9 de los 33 ya muestran una práctica **gestionada** (el nivel más alto de madurez) — son la base más sólida sobre la que construir el plan de acción, y solo requieren formalización documental para pasar a "cumplido":

Categoría	Control	ISO
Accesos y usuarios	¿El médico y la recepcionista tienen usuarios individuales en el sistema digital?	A.5.16
Equipos y red	¿El router tiene la contraseña por defecto cambiada?	A.8.20
Cumplimiento legal	¿Los pacientes firman un consentimiento informado para el tratamiento de sus datos?	A.5.31
Cumplimiento legal	¿Están inscriptos como responsables de una base de datos ante la DNPDP?	A.5.31
Datos de pacientes	¿Saben qué datos personales recopilan y dónde exactamente los guardan?	A.5.9
Datos de pacientes	¿Las historias clínicas en papel están separadas del área de acceso general?	A.7.3
Equipos y red	¿El sistema operativo de los equipos está actualizado con los últimos parches?	A.8.8
Equipos y red	¿Usan software con licencia válida en los equipos del consultorio?	A.8.19
Seguridad física	¿Las pantallas con datos de pacientes no son visibles desde la sala de espera?	A.7.7

5. Matriz de riesgo (probabilidad × impacto)

Cada uno de los 33 controles se ubica cruzando su **impacto** (ya clasificado en el checklist como alto, medio o bajo) con la **probabilidad** de que el riesgo se materialice, derivada de la madurez relevada (madurez informal o no evaluada → probabilidad alta; definida → media; gestionada → baja).

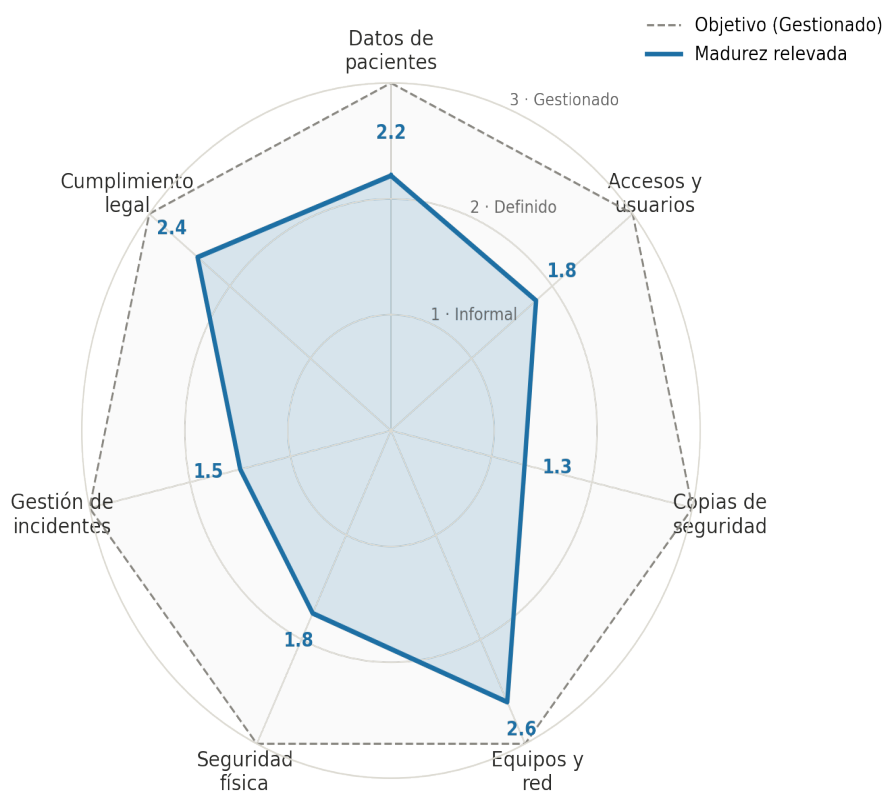


Conteo de hallazgos por celda sobre los 33 controles evaluados.

Zona crítica (recuadrada en rojo): 4 hallazgos combinan impacto alto y probabilidad alta — acceso no diferenciado a historias clínicas, revocación de accesos no confirmada, ubicación del backup sin separar del equipo principal, y ausencia de plan ante robo o pérdida de datos. Estos 4 encabezan el plan de acción (sección 7).

6. Radar de madurez por categoría

Promedio de madurez (escala 0 a 3) de los controles evaluados en cada una de las 7 categorías, contra el objetivo recomendado de "Gestionado" (3) en todos los ejes.



El perfil muestra un consultorio con controles técnicos razonables (equipos y red: 2,6) pero con dos ejes notoriamente por debajo del resto: **gestión de incidentes (1,5)** y **copias de seguridad (1,3)** — ambos vinculados a la capacidad de reacción más que a la prevención, y ambos de bajo costo de mejora.

7. Plan de acción priorizado

Prioridad	Alcance	Responsable sugerido	Plazo sugerido
1 · Crítica	4 hallazgos en zona de impacto alto + probabilidad alta (ver sección 5)	Médico responsable	0-30 días
2 · Alta	8 hallazgos restantes de riesgo alto	Médico responsable + proveedor técnico	30-60 días
3 · Media	17 hallazgos de riesgo medio	Personal administrativo + proveedor técnico	60-120 días
4 · Baja	4 hallazgos de riesgo bajo	Médico responsable	120-180 días

Primeros 4 pasos concretos (prioridad crítica):

- Definir por rol qué información del sistema puede ver cada persona (médico vs. recepción).
- Confirmar y documentar quién revoca accesos ante la salida de personal.
- Separar físicamente el backup del equipo principal (disco externo o nube).
- Redactar un procedimiento mínimo de reacción ante robo o pérdida de datos.

8. Conclusión

El consultorio no parte de cero: la madurez promedio de 2,0 sobre 3 indica que gran parte de las prácticas de seguridad ya están definidas o gestionadas de hecho, aunque ninguna quedó formalmente validada como "cumplida" en este primer relevamiento. El riesgo general es alto principalmente por 4 hallazgos concretos que combinan impacto alto con alta probabilidad de ocurrencia, y por dos categorías rezagadas — gestión de incidentes y copias de seguridad — que son, a la vez, las de menor costo de corrección. Cerrar esos 4 puntos críticos y formalizar por escrito las prácticas que ya funcionan (los 9 controles ya gestionados) debería ser suficiente para bajar el nivel de riesgo general de alto a medio en el corto plazo.

9. Nota de confidencialidad

Este documento contiene información sensible relevada durante la auditoría de seguridad del consultorio médico indicado en la portada. Su distribución debe limitarse al personal autorizado del consultorio y al equipo auditor. Queda prohibida su reproducción total o parcial sin autorización expresa del responsable del tratamiento de los datos.